TEMPLATE P55 · AI SUPPLIER DUE DILIGENCE QUESTIONNAIRE

AI supplier due diligence questionnaire

Collects the supplier's answers and evidence across the twelve due diligence blocks of document 36, at the depth required by its N1–N3 level, and assesses them before they are summarised in P14.

Fernando García Varela Version 0.2 (working draft) 19-10-2026 Draft for review

IN THIS DOCUMENT

01 Instructions for use

02 Identification

03 Assessment scale

04 Questionnaire

05 Assessment summary and transfer to P14

06 Direct or third-party verification (N3)

07 Annex A · Embedded AI questionnaire for suppliers of software already contracted

08 Quality criteria

09 Approval and verification

10 Version control

Legal notice and disclaimer. SEVEN-G is a reference methodological framework provided "as is" and for information purposes only. It does not constitute legal, regulatory, financial or professional advice, nor does it guarantee compliance with any law or standard. References to general regulation (such as the EU AI Act, the GDPR, DORA or NIS2), to technical standards and to regulation specific to each sector or jurisdiction may be incomplete, may not apply to a particular case or may become out of date as a result of regulatory changes, interpretations or supervisory positions after their consultation date. **Each organisation that uses SEVEN-G is solely responsible for identifying the regulation that applies to it, verifying that it is current and certifying its own regulatory compliance**, with the appropriate qualified advice. This methodology is a generic, free aid shared with the community so that nobody has to start from scratch; each person or organisation can and should adapt it to its own use. It must not be inferred that its legally sensitive parts have been reviewed by legal counsel: those reviews, for each company or sector, are the ultimate responsibility of the company, consultant or organisation that uses it. Although every effort is made to keep it up to date, some regulation may have changed without being reflected here. To the fullest extent permitted by law, the author accepts no responsibility whatsoever for the effects of its application in any organisation or for its full applicability. The methodology does not grant certification of any kind. The author accepts no liability for any use made of this content or for any decisions taken on the basis of it. The data, figures, companies and cases in the examples are fictitious or illustrative.

Why it matters. Accountability is not outsourced: the company is answerable to customers, supervisors and the board even if the system belongs to a third party (36 §2). Without a common questionnaire, each function asks whatever it remembers, answers cannot be compared across suppliers and the requirement level stays on paper. This questionnaire turns the twelve blocks of 36 §4.3 into specific questions with the evidence that supports them, and records what was verified before contracting.

01

Instructions for use

Aspect	Guidance
When it is used	At stage 2 of the supplier lifecycle (36 §5), in phase 3 and before G3, once the preliminary requirement level has been set in P14 §3. It is repeated whenever a reassessment trigger occurs (36 §5) and before renewing the contract. Annex A is used with suppliers of software already contracted (36 §8.1) from C1 onwards and at every R6. It is also used before testing an external AI tool with company data that is not public or synthetic: testing is also using (36 §2, principle 8).
Who completes it	The supplier answers and provides evidence. Procurement sends the questionnaire and coordinates. Assessors: the AI Technical Owner (blocks 2, 9 and 11), information security (block 5), data protection (blocks 3, 4 and 7), legal (blocks 6 and 8) and the AI Risk Owner (blocks 1, 10 and 12 and the overall assessment).
Who verifies it	Lite: the AI Risk Owner; if the AI Risk Owner has assessed the questionnaire, the AI Office or the AI Auditor verifies it. Enterprise: the AI Auditor, who checks at G3 and G5 that the due diligence matches the level (36 §11).
Who decides or approves	According to the level (36 §4.2): N1, AI Product Owner with procurement clearance; N2, AI Sponsor with risk and data protection clearance; N3, AI Committee with clearance from risk, information security, data protection and legal.
Stage or *gate*	G3 Feasibility (criteria G3.20 and G3.22); review at R6 (R6.12). Annex A: C1 and phase 6. `(phase 3)`
Tool	T09 · AI supplier register: the date and result of the due diligence are entered in the *Assessment* block of the register (P57 §3.3).
Reference document	Document 36 §4 (levels and content of the questionnaire) and §8 (embedded AI). It is used together with P14, which summarises the assessment.

Aspect	Guidance
Lite versus Enterprise	The depth depends on the N1–N3 requirement level, not on intensity (36 §2, principle 2). An N3 supplier normally implies Enterprise intensity (01 §9.2).

Completion rules:

- The questions **for the supplier's level and the levels below it** are asked: N1 answers only those marked N1 (basic questionnaire), N2 those marked N1 and N2 (full questionnaire), N3 all of them.
- Each relevant answer is supported by **evidence**; a statement without evidence is rated at most *Conformant with observations*.
- At N1, many answers are obtained from the terms of service and privacy terms published by the supplier: the version and date consulted are recorded.
- Answers that reveal a risk are carried over to P12 with the corresponding typical risk (RT-TER-01 to RT-TER-07 of document 33).
- *This document does not constitute legal advice.* References consulted in September 2026; their current validity must be verified.

02

Identification

Field	Content	Guidance
Supplier–service relationship code		PRV-AAAA-NNN from the T09 register (P57).
Supplier		Legal name, group and country of establishment.
Service or component assessed		Type of third party in 36 §1.1: model provider, platform, software with AI, integrator, data provider, open components, partner.
Linked initiatives and systems		IA-AAAA-NNN · SIA-AAAA-NNN.
Requirement level		N1 Standard · N2 Enhanced · N3 Critical, according to P14 §3.
Reason for the questionnaire		Initial selection · Reassessment trigger · Renewal · Embedded AI (annex A).
Date sent and date answered		DD-MM-AAAA.

Field	Content	Guidance
Supplier contact person		Name and position of the person who signs the answers.
Internal coordinator		Procurement or relationship manager.
Document version		

03

Assessment scale

Assessment	Meaning
Conformant	The answer meets the requirement and is supported by verifiable, current evidence.
Conformant with observations	It meets the essentials, but evidence is missing, there is a minor weakness or a condition that must be resolved before signature or before G5.
Nonconformant	It does not comply or the answer reveals a risk that is not acceptable for the level.
Not assessed	The question has not been asked or could not be assessed; the reason is explained.

The result of each block is the **worst** of its assessed questions, unless the assessor gives a written justification.

04

Questionnaire

Columns: **Level** indicates the level from which the question is asked. **Answer** is completed by the supplier; **Assessment**, by the company.

4.1 Block 1 · Identity and soundness

#	Question	Evidence requested	Level	Answer	Assessment
1.1	State your legal name, the group you belong to, your country of establishment and years in operation.	Extract from the companies register or equivalent.	N1		

#	Question	Evidence requested	Level	Answer	Assessment
1.2	Describe your ownership structure and any recent or known change of control.	Group structure chart.	N2		
1.3	What professional liability and cyber insurance do you hold, with what cover and limits?	Current insurance certificates.	N2		
1.4	Is there any conflict of interest with the company or its competitors that is relevant to the service?	Signed declaration.	N2		
1.5	Provide your financial position for the last three financial years.	Annual accounts and audit report.	N3		
1.6	Provide references from customers with comparable services.	Authorised contacts.	N3		

4.2 Block 2 · Service and model

#	Question	Evidence requested	Level	Answer	Assessment
2.1	Describe the service and the AI features it includes, in plain language.	Service sheet.	N1		
2.2	Which models does the service use? Are they proprietary or third-party? Identify the provider of each model.	List of models and providers.	N2		
2.3	Which versions are in use and what is your policy on changes and version deprecation (advance notice, version pinning)?	Versioning policy; deprecation calendar.	N2		
2.4	What model documentation do you provide: intended purpose, known limitations, evaluation results, instructions for use?	Model documentation.	N2		
2.5	Do you allow the company to carry out its own tests with representative data before contracting?	Terms of the test environment.	N2		

4.3 Block 3 · Data

#	Question	Evidence requested	Level	Answer	Assessment
3.1	Do you use the company's inputs, contexts, outputs or data to train or improve models or for other purposes? How is this excluded?	Terms of service; screenshot of the configuration.	N1		
3.2	What retention period applies to inputs, outputs and logs?	Terms; configuration.	N1		
3.3	In which regions are the data processed and stored?	Terms; region configuration.	N1		
3.4	Are there international transfers? With which Chapter V GDPR safeguards?	Transfer mechanism.	N2		
3.5	How are data encrypted in transit and at rest, and who manages the keys?	Technical description or independent report.	N2		
3.6	How are the data of different customers separated?	Architecture description.	N2		
3.7	How are data deleted on request and at the end of the contract? Do you issue a certificate?	Deletion procedure; certificate model.	N2		
***(illustrative example)* 3.1**	Do you use the inputs…?	Terms of service and screenshot.	N1	"They are not used for training on the business plan; the setting is disabled by default."	Conformant with observations: the screenshot of the configuration of the company's environment is missing.

4.4 Block 4 · Sub-processors and supply chain

#	Question	Evidence requested	Level	Answer	Assessment
4.1	Provide the list of sub-processors with their location and function.	Up-to-date list.	N2		
4.2	How do you notify changes of sub-processors? Is there advance notice and a right to object?	Change policy.	N2		
4.3	Do you pass on to your sub-processors the same obligations you assume towards the company?	Standard clause or declaration.	N2		
4.4	Do you subcontract any essential part of the service? How do you manage the subcontracting chain?	Chain map; policy.	N3		

4.5 Block 5 · Security

#	Question	Evidence requested	Level	Answer	Assessment
5.1	Which certifications and independent reports do you hold (for example, ISO/IEC 27001 or ISO/IEC 42001), and do they cover this service?	Certificates with scope and validity.	N2		
5.2	How often do you carry out penetration tests and when was the last one?	Executive summary of the last test.	N2		
5.3	How do you manage vulnerabilities and within what time frames do you fix them?	Vulnerability policy.	N2		
5.4	What protections do you apply against prompt injection, information leakage and model extraction?	Description of controls; test results.	N2		
5.5	If the service includes agents: what identity, permissions, action limits and kill switch do they have?	Description against the AG controls of document 35.	N2		
5.6	How do you authenticate and log your staff's access to the company's data?	Access policy; logs.	N2		
5.7	Do you accept adversarial testing by the company or provide recent independent reports of that type?	Testing authorisation or report.	N3		

#	Question	Evidence requested	Level	Answer	Assessment
5.8	Can you provide recent independent adversarial testing reports on the AI service (prompt injection, leakage, tool abuse), with their date and scope?	Report or executive summary.	N2		
5.9	Which input, output and action logs do you make available to the company, in what format and with what retention?	Description; sample log.	N2		
5.10	Where do the filters, monitoring and log storage of the service itself run, and which of your staff have access to them?	Description; regions.	N2		

These questions and 5.1 (ISO/IEC 42001 certification, if any) reflect the AI security purchasing criteria in 36 §4.3.

4.6 Block 6 · AI Act compliance

#	Question	Evidence requested	Level	Answer	Assessment
6.1	What role do you assume under the AI Act for this service (provider of the system, provider of a general-purpose AI model or other)?	Declaration.	N2		
6.2	How do you classify the system for the purposes of the AI Act?	Classification analysis.	N2		
6.3	What technical documentation and instructions for use do you provide so that the company can meet its obligations as deployer (Art. 26)?	Instructions for use.	N2		
6.4	What logs does the system generate and how does the company access them?	Description of logs and retention periods.	N2		
6.5	What means do you provide for human oversight?	Functional description.	N2		
6.6	How do you cooperate in handling serious incidents and in post-market monitoring?	Procedure.	N2		
6.7	If you supply a general-purpose AI model: what information and documentation do you provide on capabilities and limitations (Art. 53)?	Documentation for downstream providers.	N2		
6.8	If you supply components to a high-risk system of the company: do you accept the written agreement under Art. 25(4)?	Draft agreement.	N3		

4.7 Block 7 · Data protection

#	Question	Evidence requested	Level	Answer	Assessment
7.1	Do you act as a processor? Will you sign a data processing agreement in accordance with Art. 28 of the GDPR?	Data processing agreement.	N1		
7.2	What technical and organisational measures do you apply?	Annex of measures.	N2		
7.3	How do you support the company's impact assessments?	Information provided.	N2		
7.4	How do you support the handling of data subject rights?	Procedure.	N2		

4.8 Block 8 · Intellectual property

#	Question	Evidence requested	Level	Answer	Assessment
8.1	Who owns the outputs, or what rights of use does the company have over them?	Terms.	N2		
8.2	What information do you provide on the licences and provenance of the training data?	Declaration or documentation.	N2		
8.3	Do you offer an indemnity against infringement claims arising from the model or its training data?	Indemnity clause.	N2		
8.4	If you develop bespoke components: who owns what is developed?	Contractual proposal.	N2		

4.9 Block 9 · Continuity

#	Question	Evidence requested	Level	Answer	Assessment
9.1	What availability do you commit to and what has actual availability been over the last twelve months?	Service commitment; history.	N2		
9.2	Which third parties does the service depend on (cloud, models) and what happens if they fail?	Dependency map.	N2		

#	Question	Evidence requested	Level	Answer	Assessment
9.3	Do you have continuity and recovery plans? What recovery times do you commit to?	Plan summary.	N3		
9.4	When did you last test those plans and with what result?	Test report.	N3		

4.10 Block 10 · Incidents

#	Question	Evidence requested	Level	Answer	Assessment
10.1	How do you manage incidents and through which channel do you notify them?	Terms; procedure.	N1		
10.2	Within what time limit from detection do you notify, and with what minimum content?	Contractual commitment.	N2		
10.3	What relevant incidents has the service had in the last twenty-four months?	Summary list.	N2		
10.4	Do you cooperate in the company's response and regulatory notifications within an agreed maximum time limit (indicatively 24 hours or less)?	Contractual commitment.	N3		

4.11 Block 11 · Exit

#	Question	Evidence requested	Level	Answer	Assessment
11.1	In which formats can the company export its data?	Export documentation.	N1		
11.2	Can configurations, prompts, logs, indexes and memories also be exported?	Documentation; test.	N2		
11.3	What assistance and transition period do you offer on termination?	Contractual proposal.	N2		
11.4	How do you certify deletion on termination?	Certificate model (P57 §8).	N2		
11.5	Will you cooperate in a portability test with an alternative supplier?	Commitment.	N3		

4.12 Block 12 · Ethics and responsible use

#	Question	Evidence requested	Level	Answer	Assessment
12.1	What acceptable use policy do you apply and what use restrictions do you impose?	Published policy.	N1		
12.2	How do you assess and manage bias in the model or the service?	Metrics and evaluation results.	N2		
12.3	Does any use restriction affect the company's use case?	Assessor's analysis.	N2		

05

Assessment summary and transfer to P14

Block	Result	Observations and conditions (owner and deadline)	Risk carried over to P12
1 · Identity and soundness			
2 · Service and model			
3 · Data			
4 · Sub-processors and chain			
5 · Security			
6 · AI Act			
7 · Data protection			
8 · Intellectual property			
9 · Continuity			
10 · Incidents			
11 · Exit			

Block	Result	Observations and conditions (owner and deadline)	Risk carried over to P12
12 · Ethics and responsible use			
***(illustrative example)* 3 · Data**	Conformant with observations	Provide a screenshot of the no-training configuration before signature; procurement; 15-10-2026.	RT-TER-02

A **Nonconformant** block in data (3), security (5) or data protection (7) prevents the supplier from being used with production data until it is resolved; the conclusion is recorded in P14 §6.

06

Direct or third-party verification (N3)

Field	Content	Guidance
Type of verification		Visit · On-site document review · Report by a designated third party.
Scope		Blocks and questions verified.
Date and owner		
Result		Confirms the answers · With discrepancies.
Discrepancies and treatment		Question, discrepancy and corrected assessment.

07

Annex A · Embedded AI questionnaire for suppliers of software already contracted

It is sent to current software suppliers to identify existing or planned AI features (36 §8.1, step 1). Priority is given to software that processes personal or confidential data or that plays a part in decisions. It controls risk RT-TER-06.

7.1 Questions to the supplier

#	Question	Answer
A.1	Which AI features does the contracted software include today? Describe them in plain language.	
A.2	Which AI features do you plan to add in the next twelve months?	
A.3	Are any of them enabled by default through updates?	
A.4	Can the company keep each feature disabled until it has assessed it? How?	
A.5	Which of the company's data does each feature process? Do they include personal or confidential data?	
A.6	Are those data used to train or improve models? How is this excluded?	
A.7	Which models and model providers does each feature use and where are the data processed?	
A.8	Does any feature play a part in decisions about people or carry out actions by itself?	
A.9	How do you give notice of new AI features and model changes (release notes, advance notice)?	
A.10	Do you accept an addendum with the clauses on use of data, location, model changes and transparency on AI features (P56 §8)?	

7.2 Company assessment and decision

AI feature	Inventory code (T02)	Personal or confidential data	Plays a part in decisions or acts (A0–A3)	Can it be disabled?	N level	Decision	RT-TER-06 risk recorded
	SIA-AAAA-NNN	Yes · No		Yes · No	N1 · N2 · N3	Keep disabled · Enable with controls · Enable as an initiative	Yes · No
(illustrative example) **Automatic summary of case files in the document management system**	SIA-2026-014	Yes	A0	Yes	N2	Keep disabled until the AI Committee meeting	No

Rules in 36 §8.2: features that process personal or confidential data **must** remain disabled until assessed where the configuration allows it; if they cannot be disabled, RT-TER-06 is recorded and a decision is taken at the next AI Committee meeting; a feature that plays a part in decisions about people or acts at level A2 or A3 goes through the full lifecycle.

08

Quality criteria

#	Check	Status
1	All the questions for the supplier's level and the levels below it have been asked.	Met · Not met · Not applicable · Pending
2	Each *Conformant* assessment is supported by current evidence.	
3	The twelve blocks have a result or it is justified that they do not apply.	
4	The assessment covers security, data, use for training, intellectual property, continuity, dependency and exit at the corresponding level (G3.20).	
5	The supplier provides, or undertakes to provide, the regulatory documentation the company needs (G3.22).	
6	At N3, the direct or third-party verification is recorded.	
7	The risks identified are in P12 and the summary is in P14.	
8	The due diligence is recorded in T09 with date and result; it has been reviewed at R6 (R6.12).	
9	In annex A, each feature identified is in the inventory with its decision (D6.08 of document 11).	

09

Approval and verification

Function	Role in SEVEN-G	Name and position	Date	Signature or reference
Answers	Supplier (authorised person)			

Function	Role in SEVEN-G	Name and position	Date	Signature or reference
Coordinates	Procurement or relationship manager			
Assesses	AI Technical Owner · information security · data protection · legal · AI Risk Owner			
Verifies	AI Risk Owner or AI Office (Lite) · AI Auditor (Enterprise)			
Approves	According to the level (36 §4.2)			

Segregation of duties: whoever negotiates the contract does not assess or verify the questionnaire; anyone with a conflict of interest with the supplier declares it in P03 and does not take part in the assessment.

10

Version control

Completed document

Version	Date	Author	Changes

Template

Version	Date	Changes
0.1	19-09-2026	First version. Twelve blocks of 36 §4.3 graded by N1–N3 level, assessment scale, verification at N3 and embedded AI annex (36 §8).
0.2	19-10-2026	Questions 5.8 to 5.10 (AI security purchasing criteria, 36 §4.3) and use before any test with company data (36 §2, principle 8) (D159).

External sources cited

Links to the official or primary source, checked before publication. Always verify the version in force on the date of use.

Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) · https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng · Parlamento Europeo y Consejo de la UE · 27-04-2016

Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act) · https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng · Parlamento Europeo y Consejo de la UE · 13-06-2024

ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements · https://www.iso.org/standard/27001 · ISO/IEC (JTC 1/SC 27) · 25-10-2022

ISO/IEC 42001:2023 Information technology — Artificial intelligence — Management system · https://www.iso.org/standard/42001 · ISO/IEC (JTC 1/SC 42) · 18-12-2023